ОТЧЁТ ОБ АНАЛИЗЕ ЗАЩИЩЁННОСТИ ВЕБ-СЕРВЕРА

(Обезличенная версия для сдачи)

> Важно: В этом документе все чувствительные данные инфраструктуры заменены на плейсхолдеры:
> - <TARGET_IP> — IP-адрес целевого хоста
> - <TARGET_HOST> — hostname целевого сервера
> - <CLOUD_PROVIDER> — название облачного провайдера
> - [РЕДАКТИРОВАНО] — внутренние служебные данные

Параметр	Значение
Дата выполнения	2026 г.
Исполнитель	Студент, направление «Кибербезопасность»
Целевой объект	`<TARGET_HOST>` (IP: `<TARGET_IP>`)
Инфраструктура	`<CLOUD_PROVIDER>`, изолированная виртуальная сеть, доступ через WireGuard-VPN
Классификация	Учебный отчёт, не содержит реальных индикаторов компрометации

📋 1. ВВОДНАЯ ЧАСТЬ

1.1. Легенда и цель работы

> Вымышленный сценарий:
> Компания «Acme Security» проводит плановый аудит безопасности тестового стенда перед запуском нового веб-приложения. Цель — выявить уязвимости, оценить критичность и подготовить рекомендации по устранению.

Поставленная задача:
- Провести первичный анализ уязвимого сервера
- Выполнить поиск и эксплуатацию уязвимостей
- Составить структурированный отчёт о полученной информации

1.2. Средства и инструменты

Инструмент	Назначение
Nmap 7.95	Сканирование портов, определение сервисов и версий
Nikto 2.6.0	Поиск уязвимостей веб-серверов
Gobuster / Dirb	Поиск скрытых директорий и файлов
WPScan 3.8.28	Сканирование WordPress на уязвимости
SQLMap	Автоматизация SQL-инъекций
curl / wget	Ручной анализ веб-ресурсов
Браузер	Визуальная проверка веб-интерфейсов

1.3. Целевой сервер

Порт	Сервис	Приложение
80	HTTP	DVWA (Apache + PHP/5.4.16)
31337	HTTP	WordPress 5.3
31338	HTTP	phpMyAdmin
3306	MySQL	MariaDB 10.3.23
4000, 5000, 8000, 8080, 9090	HTTP/разное	Дополнительные сервисы

---

2. ИССЛЕДОВАТЕЛЬСКАЯ ЧАСТЬ

2.1. Этап 1: Первичное сканирование (Nmap)

Команда:
bash
sudo nmap -sS -sV -sC -p- --reason -oN scan_output.txt <TARGET_IP>

Ключевые результаты:

Порт	Сервис	Версия	Примечание
22	SSH	OpenSSH 7.4	Устаревшая версия
80	HTTP	Apache 2.4.6 + PHP/5.4.16	Критически устаревшее ПО
3306	MySQL	MariaDB 10.3.23	Доступ без аутентификации
31337	HTTP	Apache 2.4.38 + WordPress 5.3	Уязвимая версия CMS
31338	HTTP	Apache 2.4.62 + phpMyAdmin	Панель управления БД

Вывод: Обнаружено 12 открытых портов, из них 7 веб-приложений. Несколько сервисов используют версии ПО с известными уязвимостями.

2.2. Этап 2: Анализ веб-приложений

Приложение 1: DVWA (порт 80)

Инструменты: Nikto, Gobuster, ручной анализ

Найденные сущности:

- Версии: PHP/5.4.16 (EOL с 2015 г.), Apache/2.4.6 (устаревший)
- /.git/ — публичный доступ к репозиторию:
- - .git/HEAD, .git/config, .gitignore, .dockerignore
- - Remote URL: https://github.com/digininja/DVWA

- Directory Indexing на: /config/, /database/, /tests/, /docs/
- Missing security headers: CSP, HSTS, X-Content-Type-Options, X-Frame-Options
- HTTP TRACE enabled (уязвимость Cross-Site Tracing)
- PHP Easter Eggs доступны (раскрытие информации)

Критические настройки из анализа:

- allow_url_fopen = On (возможность удалённого включения файлов)
- disable_functions = [пусто] (все функции доступны)
- Отсутствуют security headers

Связанные CVE (для справки):

Компонент	Версия	Примеры CVE
PHP	5.4.16	CVE-2015-4023, CVE-2016-5093, CVE-2016-6290
Apache	2.4.6	CVE-2013-5704, CVE-2014-0117, CVE-2014-3583

Приложение 2: WordPress (порт 31337)

Инструменты: Gobuster, curl, анализ phpinfo

Найденные сущности:

- Версия: WordPress 5.3 (из Nmap)
- PHP Version: 7.1.33 (из phpinfo) — EOL с декабря 2019 г.
- Apache: 2.4.38 (Debian)
- Доступные файлы:

- /info.php (96 994 байта — полный вывод phpinfo())
- /php.ini (конфигурация PHP)
- /wp-admin/, /wp-content/, /wp-includes/
- /xmlrpc.php (Status: 405 — потенциальная цель для атак)

- /hack/ — статья "hack-me-if-you-can"

Критические настройки из phpinfo:

• allow_url_fopen = On (возможность RFI-атак)
• disable_functions = no value (нет ограничений на выполнение функций)
• display_errors = Off
• DOCUMENT_ROOT = /var/www/html
• session.cookie_httponly = Off

Связанные CVE:

Компонент	Версия	Примеры CVE
WordPress	5.3	CVE-2020-8799 (XSS), CVE-2020-8802 (SQLi), CVE-2020-36312
PHP	7.1.33	CVE-2019-11043 (RCE), CVE-2020-7060 (XSS)

Приложение 3: phpMyAdmin (порт 31338)

Найденные сущности:

- Версия Apache: 2.4.62 (Debian)
- Панель управления базами данных доступна публично
- Стандартный путь: /

Потенциальные векторы атаки:

- Подбор учётных данных по умолчанию (root/root, admin/password)
- Использование для дампа баз данных при успешной аутентификации
- Возможные уязвимости в самой версии phpMyAdmin (требует уточнения версии)

Дополнительные сервисы (кратко)

Порт	Приложение	Найденная информация
8080	Apache 2.4.7	robots.txt раскрывает: `/admin/`, `/documents/`, `/images/`, `/passwords/`
5000	Apache 2.4.7	Страница "Register Today"
8000	Python WSGI	"Task Manager"
4000	Node.js Express	Веб-приложение (детали не исследовались)
9090	Nagios NSCA	Система мониторинга

2.3. Этап 3: Сводная таблица уязвимостей

Приложение	Порт	Уязвимость	Критичность	Результат эксплуатации

DVWA	80	Exposed Git Repository	Critical	Получен доступ к `.git/`, возможна реконструкция исходного кода и поиск credentials
DVWA	80	Directory Indexing (`/config/`, `/database/`)	High	Доступ к конфигурационным файлам и директориям БД
DVWA	80	Устаревшее ПО (PHP 5.4.16, Apache 2.4.6)	High	Множество известных CVE, возможна эксплуатация
DVWA	80	Missing Security Headers	Medium	Повышает риск XSS, clickjacking, MIME-sniffing
DVWA	80	HTTP TRACE enabled	Medium	Уязвимость Cross-Site Tracing (XST)
WordPress	31337	Exposed phpinfo (`/info.php`)	High	Раскрытие версий модулей, путей, настроек безопасности
WordPress	31337	Устаревшая версия (5.3)	High	Известные уязвимости в ядре и плагинах
WordPress	31337	`/xmlrpc.php` доступен	Medium	Возможны атаки брутфорс, DDoS через pingback

phpMyAdmin	31338	Публичный доступ к панели	Medium	Риск подбора учётных данных, доступ к БД
Все сервисы	Разные	Отсутствие аутентификации	High	Прямой доступ к чувствительным функциям

---

3. ВЫВОДЫ

3.1. Выполненные операции

1. Проведено полное сканирование портов (Nmap, все 65535 портов)
2. Определены запущенные сервисы и их версии
3. Выполнен поиск скрытых директорий (Gobuster, Nikto)
4. Проанализированы конфигурационные файлы и метаданные
5. Выявлены критические уязвимости и оценена их важность
6. Составлена структурированная таблица находок

3.2. Обнаруженные приложения и уязвимости

Приложения:

1. DVWA (порт 80) — уязвимый веб-стенд для обучения
2. WordPress 5.3 (порт 31337) — система управления контентом
3. phpMyAdmin (порт 31338) — панель управления БД
4. Дополнительные сервисы (порты 4000–9090)

Критические уязвимости:

- Exposed Git Repository на DVWA — позволяет восстановить исходный код
- Exposed phpinfo на WordPress — раскрывает внутреннюю конфигурацию

- Directory Indexing на критических путях — доступ к конфигурам и БД
- Устаревшее ПО — множественные известные CVE (см. таблицу выше)

3.3. Полученная информация и её важность

Информация	Важность	Возможное использование
Ссылка на исходный репозиторий (`github.com/digininja/DVWA`)	Critical	Поиск hardcoded credentials, анализ кода на уязвимости
Версии всех компонентов	High	Подбор эксплойтов из баз CVE/Exploit-DB
Пути к файлам (`/var/www/html`)	High	Планирование атак LFI/RFI, загрузка шеллов
Настройки PHP (`allow_url_fopen=On`)	High	Возможность удалённого включения файлов (RFI)
Список скрытых директорий	Medium	Целенаправленный поиск чувствительных данных
Отсутствие security headers	Medium	Повышение эффективности XSS, clickjacking

3.4. Рекомендации по улучшению безопасности

Немедленные меры (Critical/High):

1. Заблокировать доступ к .git/:
   apache
   В .htaccess или конфигурации Apache:
   <Directory ~ "\.git">
   Require all denied
   </Directory>

2. Удалить или защитить /info.php и /php.ini:
   bash
   rm /var/www/html/info.php
   chmod 600 /var/www/html/php.ini

3. Отключить Directory Indexing:
   apache
   Options -Indexes

4. Обновить ПО до поддерживаемых версий:
   - PHP: 5.4.16 / 7.1.33 → 8.2+
   - Apache: 2.4.6 / 2.4.38 → 2.4.66+
   - WordPress: 5.3 → последняя стабильная

Среднесрочные меры (Medium):

5. Добавить security headers:
   apache
   Header set Content-Security-Policy "default-src 'self'"
   Header set X-Content-Type-Options "nosniff"
   Header set X-Frame-Options "DENY"
   Header set Strict-Transport-Security "max-age=31536000; includeSubDomains"
   Header set Referrer-Policy "strict-origin-when-cross-origin"

6. Отключить HTTP TRACE:

apache
TraceEnable Off

7. Настроить аутентификацию для админ-панелей:
   - Basic Auth или 2FA для /wp-admin/, /phpmyadmin/
   - Ограничение доступа по IP (whitelist)

Долгосрочные меры:

8. Внедрить WAF (ModSecurity, Cloudflare, NAXSI)
9. Настроить мониторинг и логирование попыток доступа к чувствительным ресурсам
10. Проводить регулярные пентесты и аудит безопасности (ежеквартально)
11. Внедрить процесс управления уязвимостями (Vulnerability Management)

ПРИЛОЖЕНИЕ: Список сохранённых файлов

- dvwa_scan.txt — вывод Nmap (сканирование портов)
- dvwa_nikto.txt — отчёт Nikto (уязвимости веб-сервера)
- dvwa_dirs.txt — результаты поиска директорий (Gobuster)
- wordpress_dirs.txt — директории WordPress
- wordpress_phpinfo.txt — полный вывод phpinfo()
- wordpress_scan.txt — попытка сканирования WPScan (требуется обновление БД)

> Примечание: Все файлы содержат только данные, полученные в рамках учебного стенда. Чувствительная информация об инфраструктуре в отчёте обезличена.

ЗАКЛЮЧЕНИЕ

В ходе практической работы проведён комплексный анализ защищённости сервера <TARGET_IP>. Выявлено 10+ уязвимостей, из них 3 критических:

1. Публичный доступ к Git-репозиторию приложения
2. Раскрытие полной конфигурации через phpinfo
3. Directory Indexing на критических путях

Получена информация, достаточная для компрометации системы в учебных целях. Рекомендации по устранению уязвимостей позволят существенно повысить уровень безопасности целевого сервера.